

****CISM® Review Manual****

****Advanced Future-Proof Edition — July 2026****

****Complete Hierarchical Table of Contents****

(Original CISM 16th Edition structure + maximum depth expansion with every relevant 2026 technology)

About This Manual

- Overview of the Advanced 2026 Edition
- Organization of This Manual
- Format of This Manual
- Preparing for the CISM Exam in the AI and Quantum Era
- Getting Started
- Using the CISM Review Manual as a Living Strategic Playbook
- Features in the Review Manual
 - AI risk scenarios and agentic safety checklists
 - Blockchain and smart-contract control mappings
 - Metaverse / Digital Twin threat models
 - Privacy-Enhancing Technologies (PETs) decision frameworks
 - Post-Quantum Cryptography migration roadmaps
 - Continuous Digital Trust dashboards
- Types of Questions on the CISM Exam (updated for autonomous systems and multi-party environments)
- Preparing for the Exam
- Using ISACA Exam Preparation Resources
- About the CISM Review Questions, Answers & Explanations Manual
- About the CISM Review Questions, Answers & Explanations Database
- About the Advanced Digital Trust, AI Assurance & Quantum Readiness Resources (2026)

Chapter 1: Information Security Governance

****Overview****

- Domain 1 Exam Content Outline (2026 updated)
- Learning Objectives / Task Statements
- Suggested Resources for Further Reading

Part A: Enterprise Governance

1.1 Importance of Information Security Governance

- 1.1.1 Outcomes of Information Security Governance
 - 1.1.1.1 Digital Trust as a Strategic Outcome
 - 1.1.1.2 AI Trustworthiness and Model Accountability
 - 1.1.1.3 Quantum Readiness and Cryptographic Resilience
 - 1.1.1.4 Metaverse and Spatial Computing Resilience
 - 1.1.1.5 Cyber-Physical and Digital Twin Integrity
- 1.1.2 Scope and Charter of Information Security Governance
 - 1.1.2.1 Traditional Information Assets
 - 1.1.2.2 AI Systems and Multi-Agent Ecosystems
 - 1.1.2.3 Blockchain Networks and Decentralized Systems
 - 1.1.2.4 Digital Twins and Industrial Metaverse Environments
 - 1.1.2.5 XR / Spatial Computing Platforms
 - 1.1.2.6 Edge AI, TinyML and Neuromorphic Systems
 - 1.1.2.7 Cyber-Physical Systems and Space-Based Assets

1.2 Organizational Culture

- 1.2.1 General Rules of Use / Acceptable Use Policy
 - 1.2.1.1 Traditional Acceptable Use
 - 1.2.1.2 AI Acceptable Use Policy
 - 1.2.1.3 Agentic AI Autonomy and Boundary Policy
 - 1.2.1.4 Synthetic Media and Deepfake Policy
 - 1.2.1.5 Continuous Authentication and Behavioral Policy
- 1.2.2 Ethics
 - 1.2.2.1 Human-AI Collaboration Ethics
 - 1.2.2.2 Algorithmic Fairness and Bias Mitigation
 - 1.2.2.3 Metaverse Psychological Safety and Identity Ethics
 - 1.2.2.4 Brain-Computer Interface Early Ethical Considerations
 - 1.2.2.5 Dual-Use and Responsible Innovation Ethics

1.3 Legal, Regulatory and Contractual Requirements

- 1.3.1 Requirements for Content and Retention of Business Records
 - 1.3.1.1 Traditional Records
 - 1.3.1.2 AI Training Data Provenance and Lineage
 - 1.3.1.3 Model Cards and System Cards
 - 1.3.1.4 Blockchain Immutable Logs and Transaction Records

- 1.3.1.5 Synthetic Data Provenance
- 1.3.1.6 XR Session and Digital Twin State Records
- 1.3.2 AI-specific, Quantum-related and Emerging Regulatory Requirements
 - 1.3.2.1 India's DPDP Act Implications for AI and Automated Decision Systems
 - 1.3.2.2 EU AI Act Full Implementation Requirements
 - 1.3.2.3 ISO/IEC 42001 Adoption Trends and Mandatory Elements
 - 1.3.2.4 Smart-Contract Enforceability and Digital Asset Regulations
 - 1.3.2.5 Emerging Quantum and Cryptographic Mandates

1.4 Organizational Structures, Roles and Responsibilities

- 1.4.1 Roles and Responsibilities
 - 1.4.1.1 Skills Required for 2026 Governance
 - 1.4.1.2 Board of Directors / Digital Trust Committee / AI Oversight Committee
 - 1.4.1.3 Senior Management and AI Executive Sponsor
 - 1.4.1.4 Business Process Owners (including AI Product Owners)
 - 1.4.1.5 Steering Committee (AI & Emerging Tech Governance Committee)
 - 1.4.1.6 Chief Information Security Officer and the "AI-as-a-CISO" Operating Model
 - 1.4.1.7 Chief AI Officer / AI Governance Lead Interface
 - 1.4.1.8 Risk Management Roles and Responsibilities
 - 1.4.1.9 Blockchain Network Security Owner
 - 1.4.1.10 Metaverse / Spatial Computing Security Owner
 - 1.4.1.11 Quantum Readiness Lead
 - 1.4.1.12 Edge AI & Neuromorphic Security Lead
 - 1.4.1.13 Cross-functional RACI for Multi-Agent Systems, Digital Twins and Decentralized Identity

Part B: Information Security Strategy

1.5 Information Security Strategy Development

- 1.5.1 Business Goals and Objectives
- 1.5.2 Information Security Strategy Objectives
 - 1.5.2.1 Trustworthy AI Objectives
 - 1.5.2.2 Quantum Readiness Objectives
 - 1.5.2.3 Metaverse and Spatial Resilience Objectives
 - 1.5.2.4 Cyber-Physical Integrity Objectives
- 1.5.3 Ensuring Objective and Business Integration
 - 1.5.3.1 Business Linkages with Enterprise AI Roadmaps
 - 1.5.3.2 Business Linkages with Agentic Automation
 - 1.5.3.3 Business Linkages with Tokenization and Digital Assets

- 1.5.3.4 Business Linkages with Spatial Computing Strategies
- 1.5.4 Avoiding Common Pitfalls and Bias
 - 1.5.4.1 AI Model Bias and Drift
 - 1.5.4.2 Over-Reliance on Autonomous Agents
 - 1.5.4.3 Blockchain Centralization and Governance Risks
 - 1.5.4.4 Digital Twin Desynchronization Risks
- 1.5.5 The Desired State
 - 1.5.5.1 COBIT for AI and Digital Trust
 - 1.5.5.2 Business Model for Information Security (updated for agentic systems)
 - 1.5.5.3 Governance, Risk Management and Compliance (GRC 2.0 with continuous AI assurance)
- 1.5.6 Information Security Strategy Development
 - 1.5.6.1 Horizon Scanning for Quantum, Agentic, Immersive and Cyber-Physical Threats (2026–2035)
- 1.5.7 Elements of a Strategy
 - 1.5.7.1 Road Map
 - 1.5.7.1.1 AI Control Maturity Roadmap
 - 1.5.7.1.2 Post-Quantum Migration Roadmap
 - 1.5.7.1.3 Metaverse Identity Strategy
 - 1.5.7.1.4 PETs Adoption Roadmap
 - 1.5.7.2 Resources and Constraints—Overview

1.6 Information Governance Frameworks and Standards

- 1.6.1 Balanced Scorecard (with AI trust, digital asset and quantum readiness metrics)
- 1.6.2 Architectural Approaches
 - 1.6.2.1 Zero Trust + AI
 - 1.6.2.2 Confidential Computing Architectures
 - 1.6.2.3 Blockchain-Anchored Identity
 - 1.6.2.4 Edge-to-Cloud Continuum Security
 - 1.6.2.5 Spatial Computing Security Architecture
- 1.6.3 Enterprise Risk Management Frameworks
- 1.6.4 Information Security / Cybersecurity / AI Management Frameworks and Models
 - 1.6.4.1 ISO/IEC 27000 Series + ISO/IEC 42001 (AIMS)
 - 1.6.4.2 NIST Cybersecurity Framework 2.0 + NIST AI Risk Management Framework
 - 1.6.4.3 NIST Risk Management Framework (adapted for AI systems)
 - 1.6.4.4 Blockchain Governance Frameworks
 - 1.6.4.5 Metaverse / Spatial Computing Security Guidance
 - 1.6.4.6 Post-Quantum Cryptography Migration Standards
 - 1.6.4.7 Confidential Computing & Privacy-Enhancing Technologies (PETs) Standards
 - 1.6.4.8 Other Approaches (FAIR for AI risk, formal verification frameworks, digital twin assurance models)

1.7 Strategic Planning

1.7.1 Workforce Composition and Skills

1.7.1.1 Organizational Structure

1.7.1.2 Centralized and Decentralized Approaches to Coordinating Information Security

1.7.1.3 Employee Roles and Responsibilities

1.7.1.4 Skills (AI literacy, agent oversight, smart-contract auditing, XR security, quantum-safe engineering, PETs engineering)

1.7.1.5 Awareness and Education

1.7.2 Assurance Provisions

1.7.2.1 Audits (AI system audits, smart-contract audits, continuous compliance for autonomous agents)

1.7.2.2 Compliance Enforcement

1.7.3 Risk Assessment and Management

1.7.3.1 Business Impact Analysis

1.7.3.2 Resource Dependency Analysis

1.7.3.3 Outsourced Services

1.7.3.4 Threat Assessment

1.7.3.5 Vulnerability Assessment

1.7.3.6 Insurance

1.7.3.7 Other Organizational Support and Assurance Providers

1.7.4 Action Plan to Implement Strategy

1.7.4.1 Gap Analysis—Basis for an Action Plan

1.7.4.1.1 AI Maturity Gap

1.7.4.1.2 Quantum Readiness Gap

1.7.4.1.3 Blockchain Maturity Gap

1.7.4.1.4 Metaverse Readiness Gap

1.7.4.2 Action Plan Metrics

1.7.4.3 Action Plan Intermediate Goals

1.7.5 Information Security Program Objectives

Chapter 2: Information Security Risk Management

Overview

- Domain 2 Exam Content Outline
- Learning Objectives / Task Statements
- Suggested Resources for Further Reading

Part A: Information Risk Assessment

2.1 Emerging Risk and Threat Landscape

2.1.1 Risk Identification

2.1.2 Threats

2.1.2.1 Internal Threats (insider + compromised AI agents)

2.1.2.2 External Threats

2.1.2.3 Advanced Persistent Threats (AI-augmented APT, deepfake-enabled social engineering, agentic APT)

2.1.3 Defining a Risk Management Framework

2.1.3.1 Defining the External Environment

2.1.3.2 Defining the Internal Environment

2.1.4 Emerging Threats

2.1.4.1 Agentic AI & Multi-Agent Systems

2.1.4.1.1 Goal Hijacking

2.1.4.1.2 Cascading Decisions

2.1.4.1.3 Emergent Behavior and Runaway Autonomy

2.1.4.2 Generative & Multimodal AI

2.1.4.2.1 Deepfakes at Industrial Scale

2.1.4.2.2 Prompt Injection at Scale

2.1.4.2.3 Model Poisoning and Training Data Leakage

2.1.4.3 Blockchain & Web3

2.1.4.3.1 Smart-Contract Exploits

2.1.4.3.2 Oracle Manipulation

2.1.4.3.3 Bridge Attacks, MEV and Governance Attacks

2.1.4.4 Metaverse / XR / Digital Twins

2.1.4.4.1 Avatar Hijacking

2.1.4.4.2 Virtual Asset Theft

2.1.4.4.3 Immersive Social Engineering

2.1.4.4.4 Digital Twin Integrity Attacks

2.1.4.5 Quantum Threats

2.1.4.5.1 Harvest-Now-Decrypt-Later

2.1.4.5.2 Cryptographic Break Risk

2.1.4.6 Edge AI / TinyML / On-Device & Neuromorphic Models

2.1.4.7 Cyber-Physical & OT/ICS Advanced Threats

2.1.4.8 Synthetic Identity & Synthetic Data Risks

2.1.4.9 Supply-Chain Risks for AI Models, Hardware Accelerators, Oracles and Satellite Systems

2.1.4.10 Space-Based and Next-Generation Networking Risks

2.1.5 Risk, Likelihood and Impact

2.1.6 Risk Register

2.1.6.1 AI System Risk Register

- 2.1.6.2 Blockchain Asset Risk Register
- 2.1.6.3 Metaverse Environment Risk Register
- 2.1.6.4 Quantum Cryptographic Risk Register

2.2 Vulnerability and Control Deficiency Analysis

- 2.2.1 Security Control Baselines
 - 2.2.1.1 AI System Baselines
 - 2.2.1.2 Smart-Contract Security Baselines
 - 2.2.1.3 XR Platform Baselines
 - 2.2.1.4 Confidential Computing Baselines
 - 2.2.1.5 Post-Quantum Cryptography Baselines
 - 2.2.1.6 Edge AI and Digital Twin Baselines
- 2.2.2 Events Affecting Security Baselines

2.3 Risk Analysis, Evaluation and Assessment

- 2.3.1 Determining the Risk Management Context
- 2.3.2 Operational Risk Management (including agentic system operational risk)
- 2.3.3 Risk Management Integration with IT Life Cycle Management Processes
 - 2.3.3.1 Traditional IT Lifecycle
 - 2.3.3.2 MLOps / LLMops / AgentOps Lifecycle
- 2.3.4 Risk Scenarios
- 2.3.5 Risk Assessment Process
- 2.3.6 Risk Assessment and Analysis Methodologies
 - 2.3.6.1 NIST Risk Assessment Methodology + NIST AI RMF
 - 2.3.6.2 ISO/IEC Process Steps + ISO/IEC 42001
 - 2.3.6.3 Cascading Risk in Multi-Agent and Blockchain Ecosystems
- 2.3.7 Other Risk Assessment Approaches
 - 2.3.7.1 Factor Analysis of Information Risk (FAIR) adapted for AI
 - 2.3.7.2 Holistic Approach to Risk Management (HARM)
 - 2.3.7.3 Probabilistic Risk Assessment for Autonomous Agents
- 2.3.8 Risk Analysis
 - 2.3.8.1 Gap Analysis
 - 2.3.8.2 Qualitative Analysis
 - 2.3.8.3 Semi-quantitative (Hybrid) Analysis
 - 2.3.8.4 Quantitative Analysis
 - 2.3.8.5 Other Risk Analysis Methods
- 2.3.9 Risk Evaluation
- 2.3.10 Risk Ranking

Part B: Information Risk Response

2.4 Risk Treatment / Risk Response Options

- 2.4.1 Determining Risk Capacity and Acceptable Risk (Risk Appetite)
 - 2.4.1.1 Risk Appetite for Levels of AI Autonomy
- 2.4.2 Risk Response Options
 - 2.4.2.1 Terminate the Activity
 - 2.4.2.2 Transfer the Risk
 - 2.4.2.3 Mitigate the Risk
 - 2.4.2.3.1 Privacy-Enhancing Technologies (PETs)
 - 2.4.2.3.2 Human-in-the-Loop Controls
 - 2.4.2.3.3 Formal Verification of Smart Contracts
 - 2.4.2.3.4 Quantum-Resistant Migration
 - 2.4.2.3.5 Kill-Switches and Circuit Breakers
 - 2.4.2.4 Accept the Risk
- 2.4.3 Risk Acceptance Framework (for autonomous decision systems)
- 2.4.4 Inherent and Residual Risk
- 2.4.5 Impact
- 2.4.6 Controls
- 2.4.7 Legal and Regulatory Requirements
- 2.4.8 Costs and Benefits

2.5 Risk and Control Ownership

- 2.5.1 Risk Ownership and Accountability
- 2.5.2 Risk Owner
- 2.5.3 Control Owner (including AI control owners)

2.6 Risk Monitoring and Reporting

- 2.6.1 Risk Monitoring
- 2.6.2 Key Risk Indicators
 - 2.6.2.1 AI KRIs (drift, hallucination rates, decision auditability, agent goal alignment)
 - 2.6.2.2 Blockchain KRIs
 - 2.6.2.3 XR / Digital Twin Integrity Metrics
 - 2.6.2.4 Quantum Readiness Metrics
 - 2.6.2.5 PETs Effectiveness Metrics
- 2.6.3 Reporting Changes in Risk
- 2.6.4 Risk Communication, Awareness and Consulting
 - 2.6.4.1 Risk Awareness

2.6.5 Documentation

2.6.5.1 AI System Cards and Model Cards

2.6.5.2 Smart-Contract Audit Reports

2.6.5.3 Digital Twin Assurance Reports

Chapter 3: Information Security Program Development and Management

Overview

- Domain 3 Exam Content Outline
- Learning Objectives / Task Statements
- Suggested Resources for Further Reading

Part A: Information Security Program Development

3.1 Information Security Program Overview

3.1.1 Information Security Management Trends

3.1.1.1 AI-Native Security Programs

3.1.1.2 Continuous Assurance

3.1.1.3 Agentic Orchestration

3.1.2 Essential Elements of an Information Security Program

3.1.3 Importance of the Information Security Program

3.1.4 Applying the Security Program Business Case

3.1.5 Outcomes of Information Security Program Management

3.1.5.1 Strategic Alignment

3.1.5.2 Risk Management

3.1.5.3 Value Delivery

3.1.5.4 Resource Management

3.1.5.5 Performance Measurement

3.1.5.6 Assurance Process Integration

3.2 Information Security Program Resources

3.2.1 Information Security Program Objectives

3.2.1.1 Defining Objectives

3.2.2 Information Security Program Concepts

3.2.2.1 Management and Process Concepts

3.2.2.2 Technology Resources (including AI agents as resources)

3.2.3 Scope and Charter of an Information Security Program

3.2.4 Common Information Security Program Challenges

3.2.4.1 Management Support

3.2.4.2 Funding

3.2.4.3 Staffing

3.2.5 Common Information Security Program Constraints

- 3.2.5.1 Physical
- 3.2.5.2 Ethics of Autonomy
- 3.2.5.3 Culture
- 3.2.5.4 Organizational Structure
- 3.2.5.5 Costs
- 3.2.5.6 Personnel
- 3.2.5.7 Resources
- 3.2.5.8 Capabilities
- 3.2.5.9 Time
- 3.2.5.10 Technology

****3.3 Information Asset Identification and Classification****

3.3.1 Information Asset Identification and Valuation

- 3.3.1.1 Traditional Information Assets
- 3.3.1.2 AI Models and Training Datasets
- 3.3.1.3 Synthetic Data
- 3.3.1.4 Smart Contracts and On-Chain Assets
- 3.3.1.5 Digital Twins and Industrial Metaverse Assets
- 3.3.1.6 Edge AI Models and Neuromorphic Systems
- 3.3.1.7 Verifiable Credentials and Decentralized Identity
- 3.3.1.8 Satellite and Space-Based Assets

3.3.2 Information Asset Valuation Strategies

3.3.3 Information Asset Classification

- 3.3.3.1 AI System Classification by Risk Tier (High-Risk AI under EU AI Act logic)

3.3.4 Methods to Determine Criticality of Assets and Impact of Adverse Events

****3.4 Industry Standards and Frameworks for Information Security****

3.4.1 Enterprise Information Security Architectures

- 3.4.1.1 Alternative Enterprise Architecture Frameworks
- 3.4.1.2 Enterprise Architecture Domains
- 3.4.1.3 Objectives of Information Security Architectures

3.4.2 Information Security Management Frameworks

- 3.4.2.1 COBIT
- 3.4.2.2 ISO/IEC 27001 + ISO/IEC 42001
- 3.4.2.3 NIST Cybersecurity Framework 2.0
- 3.4.2.4 NIST Risk Management Framework
- 3.4.2.5 NIST AI Risk Management Framework

3.4.3 Information Security Framework Components

- 3.4.3.1 Technical Components
- 3.4.3.2 Operational Components
- 3.4.3.3 Management Components
- 3.4.3.4 Administrative Components
- 3.4.3.5 Educational and Informational Components

****3.5 Information Security Policies, Procedures and Guidelines****

3.5.1 Policies

- 3.5.1.1 Policy Development
- 3.5.1.2 AI Acceptable Use & Agentic Autonomy Policy
- 3.5.1.3 Blockchain Participation Policy
- 3.5.1.4 Metaverse / XR Presence & Asset Policy
- 3.5.1.5 Synthetic Data Governance Policy
- 3.5.1.6 Post-Quantum Cryptography Policy
- 3.5.1.7 Privacy-Enhancing Technologies Policy
- 3.5.1.8 Digital Twin Integrity Policy
- 3.5.1.9 Continuous Authentication & Advanced Biometric Policy

3.5.2 Standards

- 3.5.2.1 Standards Development

3.5.3 Procedures

3.5.4 Guidelines

****3.6 Defining an Information Security Program Road Map****

3.6.1 Applying Frameworks and Architectures to Create a Program Road Map

- 3.6.1.1 Simplicity and Clarity Through Layering and Modularization
- 3.6.1.2 Business Focus Beyond the Technical Domain
- 3.6.1.3 Architecture and Control Objectives
- 3.6.1.4 Architecture Implementation
- 3.6.1.5 Security Program Management and Administrative Activities
- 3.6.1.6 Program Administration

3.6.2 Developing an Information Security Program Road Map

- 3.6.2.1 Gap Analysis as the Basis for an Action Plan

3.6.3 Life Cycle Principles Supporting the Road Map

- 3.6.3.1 AI System Lifecycle (MLOps / LLMOps / AgentOps)
- 3.6.3.2 Smart-Contract Lifecycle
- 3.6.3.3 Digital Twin Lifecycle

****3.7 Information Security Program Metrics****

3.7.1 Effective Security Metrics

- 3.7.1.1 Governance Implementation Metrics
- 3.7.1.2 Strategic Alignment Metrics
- 3.7.1.3 Risk Management Metrics
- 3.7.1.4 Value Delivery Metrics
- 3.7.1.5 Resource Management Metrics
- 3.7.1.6 Performance Measurement
- 3.7.1.7 AI Trust Metrics, Agent Decision Quality, Blockchain Finality, XR Integrity, PETs

Effectiveness, Quantum Migration Progress

3.7.2 Security Program Metrics and Monitoring

3.7.3 Metrics Tailored to Enterprise Needs

- 3.7.3.1 Strategic

3.7.3.2 Management

3.7.3.3 Operational

Part B: Information Security Program Management

3.8 Information Security Control Design and Selection

3.8.1 Managing Risk Through Controls

3.8.1.1 IT Controls

3.8.1.2 Non-IT Controls

3.8.1.3 Layered Defenses

3.8.1.4 Technologies

3.8.1.5 AI-Native Controls & Agentic Safety Controls

3.8.1.6 Privacy-Enhancing Technologies (Homomorphic Encryption, Differential Privacy, ZK Proofs, Federated Learning, Confidential Computing, Secure Multi-Party Computation)

3.8.1.7 Post-Quantum Cryptography

3.8.1.8 Formal Verification for Smart Contracts

3.8.1.9 Continuous Authentication & Behavioral Biometrics

3.8.1.10 Edge AI Security Controls

3.8.1.11 Digital Twin Integrity Controls

3.8.2 Controls and Countermeasures

3.8.3 Control Categories

3.8.4 Control Design Considerations

3.8.5 Control Methods

3.8.5.1 Countermeasures

3.8.5.2 Physical and Environmental Controls

3.8.5.3 Control Technology Categories

3.8.5.4 Technical Control Components and Architecture

3.9 Information Security Control Implementation and Integration

3.9.1 Baseline Controls

3.10 Information Security Control Testing and Evaluation

3.10.1 Control Strength

3.10.1.1 Red-Teaming of AI Agents and Smart Contracts

3.10.2 Control Recommendations

3.10.3 Control Testing and Modification

3.11 Information Security Awareness and Training

3.11.1 Security Awareness Training and Education

3.11.2 Developing an Information Security Awareness Program

3.11.3 Role-Based Training

3.11.4 Training and Education Metrics

3.12 Integration of the Security Program With IT Operations

- 3.12.1 Personnel, Roles, Skills and Culture
 - 3.12.1.1 Roles
 - 3.12.1.2 Skills
 - 3.12.1.3 Documentation
 - 3.12.1.4 Document Maintenance
- 3.12.2 Information Security Liaison Responsibilities
 - 3.12.2.1 Physical/Corporate Security
 - 3.12.2.2 IT Audit
 - 3.12.2.3 Information Technology
 - 3.12.2.4 Business Unit Managers
 - 3.12.2.5 Human Resources
 - 3.12.2.6 Legal Department
 - 3.12.2.7 Employees
 - 3.12.2.8 Procurement
 - 3.12.2.9 Compliance
 - 3.12.2.10 Privacy
 - 3.12.2.11 Training
 - 3.12.2.12 Quality Assurance
 - 3.12.2.13 Insurance
 - 3.12.2.14 Third-party Management
 - 3.12.2.15 Project Management Office
 - 3.12.2.16 AI / Data Science / MLOps / AgentOps Teams
 - 3.12.2.17 Blockchain Teams
 - 3.12.2.18 XR / Metaverse / Digital Twin Teams
- 3.12.3 Cross-Organizational Responsibilities
- 3.12.4 Issue Resolution through the Information Security Program
 - 3.12.4.1 Vendor Management
 - 3.12.4.2 Physical and Environmental Factors
 - 3.12.4.3 Cultural and Regional Variances
 - 3.12.4.4 Logistics
- 3.12.5 Integration With IT Processes
 - 3.12.5.1 Integration
 - 3.12.5.2 System Development Life Cycle Processes
 - 3.12.5.3 DevOps and DevSecOps
 - 3.12.5.4 Change Management
 - 3.12.5.5 Configuration Management
 - 3.12.5.6 Release Management
 - 3.12.5.7 MLOps / LLMops / AgentOps Integration
- 3.12.6 Cloud Computing
 - 3.12.6.1 Cloud Service Models
 - 3.12.6.2 Advantages
 - 3.12.6.3 Evaluation of Cloud Service Providers
 - 3.12.6.4 Confidential AI and Multi-Cloud AI Evaluation

****3.13 Management of External Services and Relationships****

- 3.13.1 Governance of Third-Party Relationships
- 3.13.2 Third-Party Service Providers
 - 3.13.2.1 Outsourcing and Service Providers
- 3.13.3 Outsourcing Challenges
- 3.13.4 Outsourcing Contracts
- 3.13.5 Third-Party Access

****3.14 Information Security Program Communications and Reporting****

- 3.14.1 Program Management Evaluation
 - 3.14.1.1 Program Objectives
 - 3.14.1.2 Compliance Requirements
 - 3.14.1.3 Program Management
 - 3.14.1.4 Security Operations Management
 - 3.14.1.5 Technical Security Management
 - 3.14.1.6 Resource Levels
- 3.14.2 The Plan-Do-Check-Act Cycle
- 3.14.3 Security Reviews and Audits
 - 3.14.3.1 Audits
 - 3.14.3.2 Auditors
- 3.14.4 Compliance Monitoring and Enforcement
 - 3.14.4.1 Policy Compliance
 - 3.14.4.2 Standards Compliance
 - 3.14.4.3 Resolution of Noncompliance Issues
 - 3.14.4.4 Compliance Enforcement
- 3.14.5 Monitoring Approaches
 - 3.14.5.1 Monitoring Security Activities in Infrastructure and Business Applications
 - 3.14.5.2 Determining Success of Information Security Investments
- 3.14.6 Measuring Information Security Management Performance
 - 3.14.6.1 Measuring Information Security Risk and Loss
 - 3.14.6.2 Measuring Support of Organizational Objectives
 - 3.14.6.3 Measuring Compliance
 - 3.14.6.4 Measuring Operational Productivity
 - 3.14.6.5 Measuring Security Cost-Effectiveness
 - 3.14.6.6 Measuring Organizational Awareness
 - 3.14.6.7 Measuring Effectiveness of Technical Security Architecture
 - 3.14.6.8 Measuring Effectiveness of Management Framework and Resources
 - 3.14.6.9 Measuring Operational Performance
- 3.14.7 Ongoing Monitoring and Communication

Chapter 4: Incident Management

****Overview****

- Domain 4 Exam Content Outline
- Learning Objectives / Task Statements
- Suggested Resources for Further Reading

Part A: Incident Management Readiness

****4.1 Incident Management and Incident Response Overview****

- 4.1.1 The Relationship Between Incident Management and Incident Response
 - 4.1.1.1 Traditional Relationship
 - 4.1.1.2 Autonomous and Agentic Response Relationship
- 4.1.2 Goals of Incident Management and Incident Response
- 4.1.3 Incident Handling and Incident Management Life Cycle

****4.2 Incident Management and Incident Response Plans****

- 4.2.1 Importance of Incident Management
- 4.2.2 Outcomes of Incident Management
- 4.2.3 Incident Management Resources
- 4.2.4 Policies and Standards
- 4.2.5 Incident Management Objectives
- 4.2.6 Strategic Alignment
- 4.2.7 Response and Recovery Plan
- 4.2.8 The Role of the Information Security Manager in Incident Management
 - 4.2.8.1 Traditional Role
 - 4.2.8.2 AI-as-a-CISO Role in Incident Management
- 4.2.9 Risk Management
- 4.2.10 Assurance Process Integration
- 4.2.11 Value Delivery
- 4.2.12 Resource Management
- 4.2.13 Defining Incident Management Procedures
- 4.2.14 Detailed Plan of Action for Incident Management
- 4.2.15 Current State of Incident Response Capability
 - 4.2.15.1 History of Incidents
 - 4.2.15.2 Threats
 - 4.2.15.3 Vulnerabilities
- 4.2.16 Developing an Incident Response Plan
 - 4.2.16.1 Elements of an Incident Response Plan
 - 4.2.16.1.1 Agent Kill-Switches
 - 4.2.16.1.2 Model Rollback Procedures
 - 4.2.16.1.3 Blockchain Pause Mechanisms
 - 4.2.16.1.4 Digital Twin Freeze Procedures
 - 4.2.16.2 Gap Analysis—Basis for an Incident Response Plan
 - 4.2.16.3 Logistics
- 4.2.17 Incident Management and Response Teams

- 4.2.17.1 Human + AI Agent Hybrid Teams
- 4.2.18 Organizing, Training and Equipping the Response Staff
- 4.2.19 Incident Notification Process
- 4.2.20 Challenges in Developing an Incident Management Plan

****4.3 Business Impact Analysis****

- 4.3.1 Elements of a Business Impact Analysis
- 4.3.2 Benefits of Conducting a Business Impact Analysis

****4.4 Business Continuity Plan****

- 4.4.1 Integrating Incident Response With Business Continuity
- 4.4.2 Methods for Providing Continuity of Network Services
- 4.4.3 High-Availability Considerations
- 4.4.4 Insurance

****4.5 Disaster Recovery Plan****

- 4.5.1 Business Continuity and Disaster Recovery Procedures
- 4.5.2 Recovery Operations
- 4.5.3 Evaluating Recovery Strategies
- 4.5.4 Addressing Threats
- 4.5.5 Recovery Sites
- 4.5.6 Basis for Recovery Site Selections
- 4.5.7 Response and Recovery Strategy Implementation
 - 4.5.7.1 Recovery of AI Models and Training Data Integrity
 - 4.5.7.2 Smart-Contract State Recovery
 - 4.5.7.3 Digital Twin State Recovery
 - 4.5.7.4 Post-Quantum Key Recovery

****4.6 Incident Classification / Categorization****

- 4.6.1 Escalation Process for Effective Incident Management
- 4.6.2 Help/Service Desk Processes for Identifying Security Incidents
 - 4.6.2.1 New Categories for Agentic, AI, Blockchain, XR, Quantum and Cyber-Physical Incidents

****4.7 Incident Management Training, Testing and Evaluation****

- 4.7.1 Incident Management Roles and Responsibilities
 - 4.7.1.1 Senior Management Commitment
 - 4.7.1.2 Responsibilities
- 4.7.2 Incident Management Metrics and Indicators
 - 4.7.2.1 Recovery Time Objectives
 - 4.7.2.2 Recovery Point Objectives
 - 4.7.2.3 Service Delivery Objectives
 - 4.7.2.4 Maximum Tolerable Outage
 - 4.7.2.5 Allowable Interruption Window

- 4.7.2.6 Maximum Tolerable Model Degradation
- 4.7.3 Performance Measurement
- 4.7.4 Updating Recovery Plans
- 4.7.5 Testing Incident Response and Business Continuity/Disaster Recovery Plans
- 4.7.6 Periodic Testing of the Response and Recovery Plans
- 4.7.7 Testing for Infrastructure and Critical Business Applications
- 4.7.8 Types of Tests
 - 4.7.8.1 Autonomous Agent Simulation
 - 4.7.8.2 Smart-Contract War Games
- 4.7.9 Test Results
- 4.7.10 Recovery Test Metrics

Part B: Incident Management Operations

****4.8 Incident Management Tools and Technologies****

- 4.8.1 Incident Management Systems
 - 4.8.1.1 Endpoint Detection and Response
 - 4.8.1.2 Extended Detection and Response
 - 4.8.1.3 Managed Detection and Response
 - 4.8.1.4 AI-Native Detection and Agentic Response Platforms
 - 4.8.1.5 Blockchain Monitoring & Freeze Mechanisms
 - 4.8.1.6 XR Security Platforms
- 4.8.2 Incident Response Technology Foundations
- 4.8.3 Personnel
 - 4.8.3.1 Incident Response Team Organization
 - 4.8.3.2 Roles and Responsibilities
- 4.8.4 Skills
- 4.8.5 Awareness and Education
- 4.8.6 Audits
- 4.8.7 Outsourced Security Providers

****4.9 Incident Investigation and Evaluation****

- 4.9.1 Executing Response and Recovery Plans
 - 4.9.1.1 Ensuring Execution as Required

****4.10 Incident Containment Methods****

- 4.10.1 Agent Isolation
- 4.10.2 Model Quarantine
- 4.10.3 Smart-Contract Pause / Freeze
- 4.10.4 Metaverse Region Lockdown
- 4.10.5 Digital Twin Freeze

****4.11 Incident Response Communications****

- 4.11.1 Notification Requirements

4.11.2 Communication Networks

****4.12 Incident Eradication and Recovery****

4.12.1 Eradication Activities

4.12.2 Recovery

****4.13 Post-Incident Review Practices****

4.13.1 Identifying Causes and Corrective Actions

4.13.2 Documenting Events

4.13.3 Establishing Legal Procedures to Assist in Post-incident Activities

4.13.4 Requirements for Evidence

4.13.4.1 AI Decision Logs and Model Cards

4.13.4.2 Blockchain Forensic Evidence

4.13.4.3 XR Session Evidence

4.13.5 Legal Aspects of Forensic Evidence

****CISM® Review Manual****

****Advanced Future-Proof Edition — July 2026****

****Complete Hierarchical Table of Contents****

(Original CISM 16th Edition structure fully preserved + maximum depth expansion)

Chapter 5: Emerging & Converging Technologies Security

**** (New Domain — July 2026) ****

****5.1 Quantum Computing & Post-Quantum Cryptography****

5.1.1 Threat Timeline & Harvest-Now-Decrypt-Later

5.1.1.1 Current Cryptographic Vulnerability Window

5.1.1.2 Nation-State and Advanced Adversary Capabilities (2026–2035)

5.1.2 Migration Strategies

5.1.2.1 Hybrid Cryptography Approaches

5.1.2.2 Crypto-Agility Frameworks

5.1.2.3 Cryptographic Inventory and Discovery

5.1.2.4 Priority-Based Migration Roadmap (Critical Systems First)

5.1.2.5 Testing, Validation and Rollback Procedures

****5.2 Blockchain, Web3, Tokenization & Decentralized Systems****

5.2.1 Enterprise Blockchain Security

5.2.1.1 Permissioned vs Permissionless Network Security

5.2.1.2 Consensus Mechanism Risks and Controls

5.2.1.3 Node Security and Key Management

- 5.2.2 Smart-Contract Lifecycle Security & Formal Verification
 - 5.2.2.1 Secure Development Lifecycle for Smart Contracts
 - 5.2.2.2 Formal Verification Techniques
 - 5.2.2.3 Audit Requirements and Continuous Monitoring
 - 5.2.2.4 Upgradeability and Governance Controls
- 5.2.3 Decentralized Identity (DID) and Verifiable Credentials
 - 5.2.3.1 DID Architecture Security
 - 5.2.3.2 Verifiable Credential Issuance, Presentation and Revocation
 - 5.2.3.3 Wallet Security and Recovery Mechanisms
- 5.2.4 Digital Asset Custody and Tokenization Risks
 - 5.2.4.1 Hot vs Cold Custody Models
 - 5.2.4.2 Multi-Signature and MPC Custody
 - 5.2.4.3 Tokenization of Real-World Assets – Security Considerations
 - 5.2.4.4 Cross-Chain Bridge and Interoperability Risks

****5.3 Metaverse, Spatial Computing, XR & Digital Twins****

- 5.3.1 Architecture Security
 - 5.3.1.1 Persistent World Infrastructure Security
 - 5.3.1.2 Edge Rendering and Content Delivery Security
 - 5.3.1.3 Interoperability and Cross-Platform Risks
- 5.3.2 Identity, Authentication & Avatar Security
 - 5.3.2.1 Avatar Hijacking and Impersonation
 - 5.3.2.2 Continuous Authentication in Immersive Environments
 - 5.3.2.3 Biometric and Behavioral Authentication in XR
- 5.3.3 Virtual Economy & Asset Protection
 - 5.3.3.1 Virtual Asset Theft and Fraud
 - 5.3.3.2 NFT and Digital Collectible Security
 - 5.3.3.3 In-World Transaction Monitoring
- 5.3.4 Industrial Metaverse & Digital Twin Integrity
 - 5.3.4.1 Digital Twin Data Integrity and Synchronization
 - 5.3.4.2 Bidirectional Control Risks (Physical ↔ Digital)
 - 5.3.4.3 Simulation Manipulation and Integrity Attacks
- 5.3.5 Ethical, Psychological and Regulatory Considerations
 - 5.3.5.1 Psychological Safety and Addiction Risks
 - 5.3.5.2 Identity and Privacy in Persistent Virtual Worlds
 - 5.3.5.3 Regulatory Landscape for Immersive Environments

****5.4 Edge AI, TinyML, On-Device & Neuromorphic Computing****

- 5.4.1 Security of Distributed Inference
 - 5.4.1.1 Model Confidentiality on Edge Devices
 - 5.4.1.2 Secure Model Update and Distribution
- 5.4.2 Model Extraction, Side-Channel and Physical Attacks
 - 5.4.2.1 Model Extraction Attacks
 - 5.4.2.2 Side-Channel Attacks on Edge Hardware

- 5.4.2.3 Physical Tampering and Hardware Security Modules
- 5.4.3 Neuromorphic Computing Security Considerations
 - 5.4.3.1 Emerging Attack Surfaces in Spiking Neural Networks
 - 5.4.3.2 Early Governance and Control Frameworks

****5.5 Privacy-Enhancing Technologies (PETs)****

- 5.5.1 Homomorphic Encryption
 - 5.5.1.1 Fully Homomorphic Encryption (FHE) Maturity and Use Cases
 - 5.5.1.2 Performance and Key Management Challenges
- 5.5.2 Differential Privacy
 - 5.5.2.1 Privacy Budget Management
 - 5.5.2.2 Utility vs Privacy Trade-offs
- 5.5.3 Secure Multi-Party Computation (SMPC)
- 5.5.4 Zero-Knowledge Proofs (ZKPs)
 - 5.5.4.1 zk-SNARKs, zk-STARKs and Application Patterns
- 5.5.5 Confidential Computing
 - 5.5.5.1 Trusted Execution Environments (TEEs)
 - 5.5.5.2 Attestation and Secure Enclaves
- 5.5.6 Federated Learning Security
 - 5.5.6.1 Poisoning and Inference Attacks in Federated Settings
 - 5.5.6.2 Secure Aggregation Techniques

****5.6 Synthetic Data, Synthetic Media & Deepfake Defense****

- 5.6.1 Generation, Validation and Governance of Synthetic Data
 - 5.6.1.1 Quality and Fidelity Controls
 - 5.6.1.2 Provenance and Watermarking
- 5.6.2 Synthetic Media and Deepfake Detection
 - 5.6.2.1 Detection Technologies and Limitations
 - 5.6.2.2 Organizational Response Playbooks
- 5.6.3 Legal and Evidentiary Considerations

****5.7 Cyber-Physical, OT/ICS, IoT & Space Systems****

- 5.7.1 Advanced Convergence Risks and Controls
 - 5.7.1.1 IT/OT Convergence Attack Paths
 - 5.7.1.2 Safety-Critical System Security
- 5.7.2 Satellite and Space-Based Asset Security
 - 5.7.2.1 Ground Segment Security
 - 5.7.2.2 Space Segment and Link Security
 - 5.7.2.3 Emerging Space Cyber Norms and Governance

****5.8 Next-Generation Networking & Other Emerging Areas****

- 5.8.1 6G Security Considerations
 - 5.8.1.1 AI-Native Network Security
 - 5.8.1.2 Massive IoT and Ultra-Reliable Low-Latency Security

5.8.2 Brain-Computer Interfaces — Early Risk Landscape

5.8.2.1 Neural Data Privacy and Integrity

5.8.2.2 Early Governance and Ethical Frameworks

Chapter 6: Digital Trust, AI Governance & Autonomous Systems Assurance

(New Domain — July 2026)

6.1 AI Governance Frameworks

6.1.1 ISO/IEC 42001 Implementation

6.1.1.1 Establishing an AI Management System (AIMS)

6.1.1.2 Risk-Based Approach to AI Systems

6.1.1.3 Continual Improvement of AI Governance

6.1.2 NIST AI Risk Management Framework Operationalization

6.1.2.1 Govern, Map, Measure, Manage Functions

6.1.2.2 Integration with Existing GRC Processes

6.1.3 Organizational AI Governance Structures and Accountability

6.1.3.1 Board-Level AI Oversight

6.1.3.2 AI Ethics and Risk Committees

6.1.3.3 Clear Accountability for High-Risk AI Systems

6.2 Agentic AI & Multi-Agent Systems Assurance

6.2.1 Safety, Goal Alignment, Observability, Kill-Switches and Human Oversight Models

6.2.1.1 Goal Alignment Techniques

6.2.1.2 Observability and Decision Logging

6.2.1.3 Kill-Switch and Circuit-Breaker Design

6.2.1.4 Human-in-the-Loop and Human-on-the-Loop Models

6.2.2 Trust & Safety in Human-Agent Collaboration

6.2.2.1 Trust Calibration

6.2.2.2 Handover Protocols Between Human and Agent

6.2.3 Emergent Behavior Detection and Control

6.2.3.1 Monitoring for Unexpected Collective Behavior

6.2.3.2 Containment Strategies for Multi-Agent Systems

6.3 AI-as-a-CISO Operating Model

6.3.1 Practical Frameworks for AI-Powered Capabilities

6.3.1.1 Continuous Threat Detection and Prioritization

6.3.1.2 Autonomous Policy Enforcement and Control Adjustment

6.3.1.3 AI-Assisted Incident Triage and Response Orchestration

6.3.1.4 Ethical Governance and Guardrails

6.3.2 Board Reporting on Digital Trust and AI Risk

6.3.2.1 Digital Trust Dashboards

6.3.2.2 AI Risk Heat Maps and Trend Reporting

6.3.3 Measuring the Performance of the AI-Augmented CISO Function

****6.4 Continuous Assurance & Audit of Intelligent Systems****

6.4.1 Model Cards, System Cards and Continuous Monitoring

6.4.2 Red-Teaming of Agents, Smart-Contract Audits and Digital Twin Assurance

6.4.3 Independent Assurance of PETs and Quantum-Resistant Implementations

6.4.4 Continuous Control Monitoring for Autonomous Systems

****6.5 Building Organizational Digital Trust****

6.5.1 Metrics and Maturity Models for AI-Native Security Programs

6.5.1.1 Digital Trust Maturity Model

6.5.1.2 AI Governance Maturity Levels

6.5.2 Skills Transformation and Talent Strategy

6.5.3 Ecosystem Partnerships and Collective Defense

6.5.4 Regulatory Engagement and Long-Term Resilience Strategy (2026–2035)

Appendices

****Appendix A: CISM Exam General Information (Updated for 2026)****

****Appendix B: CISM Job Practice****

(Fully mapped to AI-era, quantum-era, immersive and autonomous systems responsibilities)

****Appendix C: AI System Risk Taxonomy and Comprehensive Control Catalog****

C.1 Risk Taxonomy for Traditional, AI, Agentic, Blockchain and Immersive Systems

C.2 Control Catalog Mapped to ISO/IEC 42001, NIST AI RMF and Classic CISM Domains

****Appendix D: Smart-Contract Security Checklist and Formal Verification Framework****

****Appendix E: Metaverse / Digital Twin Threat Model and Control Mapping****

****Appendix F: Post-Quantum Cryptography Migration Roadmap and Crypto-Agility Playbook****

****Appendix G: Sample Policies and Templates****

G.1 AI Acceptable Use & Agentic Autonomy Policy

G.2 Synthetic Data Governance Policy

G.3 Digital Twin Integrity Policy

G.4 Post-Quantum Cryptography Policy

G.5 Model Card and System Card Templates

G.6 Continuous Assurance Templates

****Appendix H: RACI Matrices, Maturity Models and Decision Frameworks****

****Glossary and Acronyms****

(Fully expanded for Agentic AI, PETs, Quantum, XR, Digital Twins, Neuromorphic Computing, Space Systems, etc.)

2m 13s

Appendices

Complete Hierarchical Table of Contents

(Advanced Future-Proof Edition — July 2026)

Appendix A: CISM Exam General Information (Updated for 2026)

A.1 Purpose of the CISM Certification in 2026

A.1.1 Evolution of the CISM Credential

A.1.1.1 Original Focus (Information Security Management)

A.1.1.2 2026 Reality — Digital Trust, AI Governance and Autonomous Systems Leadership

A.1.2 Value of CISM for Modern Security Leaders

A.1.2.1 Board-Level Credibility

A.1.2.2 Alignment with ISO/IEC 42001, NIST AI RMF and Emerging Regulations

A.1.2.3 Recognition in AI-Native, Quantum-Ready and Multi-Party Environments

A.2 Eligibility Requirements (2026)

A.2.1 Work Experience Requirements

A.2.1.1 Minimum Five Years of Information Security Management Experience

A.2.1.2 Acceptable Experience in AI Governance, Blockchain Security, Digital Trust and Emerging Technology Risk

A.2.1.3 Waivers and Substitutions

A.2.2 Experience Verification Process

A.2.3 Maintaining Eligibility After Passing the Exam

A.3 CISM Exam Structure (2026 Edition)

A.3.1 Number of Questions and Duration

A.3.2 Question Format

A.3.2.1 Traditional Scenario-Based Questions

A.3.2.2 New Question Styles (Agentic AI, Blockchain Governance, Digital Twin, Quantum Migration)

A.3.3 Domain Weightage (Updated 2026)

A.3.3.1 Domain 1 – Information Security Governance

A.3.3.2 Domain 2 – Information Security Risk Management

A.3.3.3 Domain 3 – Information Security Program Development and Management

A.3.3.4 Domain 4 – Information Security Incident Management

A.3.3.5 Emerging Content Integration Across Domains

A.4 Exam Content Outline Mapping

A.4.1 Domain 1 Mapping (Governance + AI Governance + Quantum Readiness)

A.4.2 Domain 2 Mapping (Risk + Agentic AI Risk + Blockchain Risk + Digital Twin Risk)

A.4.3 Domain 3 Mapping (Program + AI-Native Programs + PETs + Post-Quantum Controls)

A.4.4 Domain 4 Mapping (Incident Management + Autonomous Response + Smart-Contract Freeze)

A.5 Scoring and Results

A.5.1 Scaled Scoring System

A.5.2 Passing Score

A.5.3 Score Report Interpretation

A.6 Examination Administration

A.6.1 Computer-Based Testing

A.6.2 Remote Online Proctoring

A.6.3 Special Accommodations

A.7 Preparation Strategy for the 2026 Advanced Content

A.7.1 Recommended Study Sequence

A.7.2 Official ISACA Resources

A.7.3 Supplementary Resources (ISO 42001, NIST AI RMF, PQC, Blockchain, Metaverse)

A.7.4 Practice Question Strategy

A.7.5 Common Pitfalls

A.8 Maintaining the CISM Certification (2026 CPE Requirements)

A.8.1 CPE Hours

A.8.2 Acceptable CPE Activities (including AI, Quantum, Blockchain and Digital Trust)

A.8.3 CPE Reporting and Audit

A.9 Transition Guidance for Existing CISM Holders

A.10 Frequently Asked Questions (2026)

Appendix B: CISM Job Practice

(Fully mapped to AI-era, quantum-era, immersive and autonomous systems responsibilities)

B.1 Overview of the Updated Job Practice

B.1.1 Purpose of the Job Practice

B.1.2 How the 2026 Job Practice Differs from Previous Versions

B.2 Domain 1 — Information Security Governance (Updated Task Statements)

B.2.1 Traditional Governance Tasks

B.2.2 New / Expanded Tasks

B.2.2.1 Establish and maintain AI Governance and Digital Trust frameworks

B.2.2.2 Oversee Quantum Readiness and Crypto-Agility programs

B.2.2.3 Govern Multi-Agent and Autonomous Systems

B.2.2.4 Establish Metaverse / Spatial Computing and Digital Twin governance

B.3 Domain 2 — Information Security Risk Management (Updated Task Statements)

B.3.1 Traditional Risk Tasks

B.3.2 New / Expanded Tasks

B.3.2.1 Identify and assess Agentic AI and Multi-Agent system risks

B.3.2.2 Assess Blockchain, Smart-Contract and Digital Asset risks

B.3.2.3 Assess Metaverse, XR and Digital Twin risks

B.3.2.4 Assess Quantum and Post-Quantum cryptographic risks

B.3.2.5 Assess PETs, Edge AI and Cyber-Physical risks

B.4 Domain 3 — Information Security Program Development and Management (Updated Task Statements)

B.4.1 Traditional Program Tasks

B.4.2 New / Expanded Tasks

B.4.2.1 Develop and manage AI-Native security programs and AgentOps

B.4.2.2 Implement and manage PETs and Confidential Computing controls

B.4.2.3 Implement Post-Quantum Cryptography migration

B.4.2.4 Manage Digital Twin integrity and Spatial Computing security programs

B.4.2.5 Manage Smart-Contract security and formal verification processes

B.5 Domain 4 — Information Security Incident Management (Updated Task Statements)

B.5.1 Traditional Incident Management Tasks

B.5.2 New / Expanded Tasks

B.5.2.1 Manage Autonomous and Agentic incident response

B.5.2.2 Execute Smart-Contract freeze / pause procedures

B.5.2.3 Execute Digital Twin freeze and re-synchronization

B.5.2.4 Manage forensic requirements for AI decision logs and synthetic media

B.5.2.5 Coordinate multi-party incident response in blockchain and metaverse environments

B.6 Emerging Cross-Domain Responsibilities

B.6.1 AI-as-a-CISO Operating Model Responsibilities

B.6.2 Digital Trust Leadership Responsibilities

B.6.3 Continuous Assurance of Intelligent Systems

B.7 Knowledge and Skill Requirements (2026)

B.7.1 Traditional Knowledge Areas

B.7.2 New Knowledge Areas

B.7.2.1 Agentic AI Safety and Goal Alignment

B.7.2.2 Post-Quantum Cryptography

B.7.2.3 Privacy-Enhancing Technologies

B.7.2.4 Smart-Contract Security and Formal Verification

B.7.2.5 Digital Twin and Spatial Computing Security

B.7.2.6 Cyber-Physical and Space Systems Security

Appendix C: AI System Risk Taxonomy and Comprehensive Control Catalog

C.1 Risk Taxonomy for Traditional, AI, Agentic, Blockchain and Immersive Systems

C.1.1 Traditional Information Security Risks

C.1.2 AI System Risks

C.1.2.1 Model Risk (Bias, Drift, Hallucination, Poisoning)

C.1.2.2 Data Risk (Training Data Integrity, Provenance, Leakage)

C.1.2.3 Pipeline and MLOps Risk

C.1.3 Agentic AI and Multi-Agent System Risks

C.1.3.1 Goal Hijacking and Misalignment

C.1.3.2 Cascading and Emergent Behavior Risk

C.1.3.3 Autonomy and Control Loss Risk

C.1.4 Blockchain and Smart-Contract Risks

C.1.4.1 Smart-Contract Vulnerability Risk

C.1.4.2 Oracle and Bridge Risk

C.1.4.3 Consensus and Governance Risk

C.1.5 Metaverse, XR and Digital Twin Risks

C.1.5.1 Avatar and Identity Risk

C.1.5.2 Virtual Asset and Economic Risk

C.1.5.3 Digital Twin Integrity and Synchronization Risk

C.1.6 Quantum and Cryptographic Risks

C.1.7 Edge AI, PETs and Cyber-Physical Risks

C.1.8 Cross-Domain Cascading Risk Categories

C.2 Control Catalog Mapped to ISO/IEC 42001, NIST AI RMF and Classic CISM Domains

C.2.1 Governance and Accountability Controls

C.2.2 Risk Assessment and Treatment Controls

C.2.3 Technical Controls for AI Systems

C.2.3.1 Model Development and Validation Controls

C.2.3.2 Runtime Monitoring and Guardrail Controls

C.2.3.3 Kill-Switch and Human Oversight Controls

C.2.4 Controls for Agentic and Multi-Agent Systems

C.2.5 Controls for Blockchain and Smart Contracts

C.2.6 Controls for Metaverse, XR and Digital Twins

C.2.7 Privacy-Enhancing Technologies Controls

C.2.8 Post-Quantum Cryptography Controls

C.2.9 Mapping Tables

C.2.9.1 Control Mapping to ISO/IEC 42001

C.2.9.2 Control Mapping to NIST AI RMF

C.2.9.3 Control Mapping to Classic CISM Domains

Appendix D: Smart-Contract Security Checklist and Formal Verification Framework

D.1 Smart-Contract Security Lifecycle

D.1.1 Secure Design Phase

D.1.2 Secure Development Phase

D.1.3 Pre-Deployment Verification Phase

D.1.4 Deployment and Runtime Monitoring Phase

D.1.5 Incident Response and Upgrade Phase

D.2 Comprehensive Smart-Contract Security Checklist

D.2.1 Access Control and Authorization Checks

D.2.2 Reentrancy and External Call Risks

D.2.3 Integer Overflow / Underflow and Arithmetic Risks

D.2.4 Logic and Business Rule Validation

D.2.5 Oracle and External Data Dependency Checks

D.2.6 Upgradeability and Proxy Pattern Risks

D.2.7 Gas Optimization and Denial-of-Service Risks

D.2.8 Cryptographic Implementation Checks

D.3 Formal Verification Framework

D.3.1 When Formal Verification is Required

- D.3.2 Formal Verification Tools and Approaches
- D.3.3 Specification Writing Guidelines
- D.3.4 Integration of Formal Verification into the Development Pipeline

- D.3.5 Limitations and Complementary Assurance Methods

D.4 Audit and Continuous Assurance Requirements

- D.4.1 Independent Audit Scope
- D.4.2 Continuous Monitoring of Deployed Contracts
- D.4.3 Bug Bounty and Responsible Disclosure Integration

Appendix E: Metaverse / Digital Twin Threat Model and Control Mapping

E.1 Metaverse Threat Model

- E.1.1 Identity and Avatar Threats
- E.1.2 Virtual Asset and Economic Threats
- E.1.3 Immersive Social Engineering and Psychological Threats
- E.1.4 Platform and Infrastructure Threats
- E.1.5 Interoperability and Cross-World Threats

E.2 Digital Twin Threat Model

- E.2.1 Data Integrity and Synchronization Threats
- E.2.2 Bidirectional Control Threats (Physical ↔ Digital)
- E.2.3 Simulation Manipulation Threats
- E.2.4 Model Fidelity and Drift Threats

E.3 Control Mapping

- E.3.1 Identity and Authentication Controls
- E.3.2 Asset Protection and Transaction Monitoring Controls
- E.3.3 Integrity and Synchronization Controls
- E.3.4 Monitoring, Detection and Response Controls
- E.3.5 Governance and Ethical Controls

E.4 Industrial Metaverse Specific Considerations

Appendix F: Post-Quantum Cryptography Migration Roadmap and Crypto-Agility Playbook

F.1 Current Cryptographic Landscape and Quantum Threat Timeline

F.1.1 Vulnerable Algorithms

F.1.2 Harvest-Now-Decrypt-Later Reality

F.1.3 Projected Timeline for Cryptographically Relevant Quantum Computers

F.2 Cryptographic Inventory and Discovery

F.2.1 Discovery Methods

F.2.2 Classification of Cryptographic Assets

F.2.3 Priority Ranking Criteria

F.3 Migration Roadmap

F.3.1 Phase 1 — Preparation and Inventory

F.3.2 Phase 2 — Hybrid Cryptography Deployment

F.3.3 Phase 3 — Full Post-Quantum Migration

F.3.4 Phase 4 — Decommissioning of Vulnerable Algorithms

F.3.5 Continuous Crypto-Agility Maintenance

F.4 Crypto-Agility Playbook

F.4.1 Design Principles for Crypto-Agile Systems

F.4.2 Algorithm Negotiation and Agility Mechanisms

F.4.3 Testing and Validation Strategies

F.4.4 Rollback and Contingency Procedures

F.5 Governance, Risk and Compliance Considerations

F.5.1 Board and Executive Reporting

F.5.2 Regulatory and Contractual Implications

F.5.3 Third-Party and Supply-Chain Requirements

Appendix G: Sample Policies and Templates

G.1 AI Acceptable Use & Agentic Autonomy Policy

G.1.1 Purpose and Scope

G.1.2 Definitions (AI System, Agentic System, Autonomy Levels)

G.1.3 Acceptable Use Rules

G.1.4 Autonomy Boundaries and Human Oversight Requirements

G.1.5 Prohibited Uses

G.1.6 Monitoring, Audit and Enforcement

G.1.7 Roles and Responsibilities

G.1.8 Exceptions and Review Process

G.2 Synthetic Data Governance Policy

G.2.1 Purpose and Scope

G.2.2 Generation Standards

G.2.3 Validation and Quality Controls

G.2.4 Provenance, Watermarking and Lineage

G.2.5 Usage Restrictions

G.2.6 Retention and Destruction

G.3 Digital Twin Integrity Policy

G.3.1 Purpose and Scope

G.3.2 Data Integrity Requirements

G.3.3 Synchronization and Bidirectional Control Rules

G.3.4 Change Management for Digital Twins

G.3.5 Monitoring and Incident Response

G.4 Post-Quantum Cryptography Policy

G.4.1 Purpose and Scope

G.4.2 Cryptographic Inventory Requirements

G.4.3 Migration Timeline and Priorities

G.4.4 Hybrid and Crypto-Agile Requirements

G.4.5 Third-Party and Vendor Requirements

G.5 Model Card and System Card Templates

G.5.1 Standard Model Card Template

G.5.2 Standard System Card Template

G.5.3 Agentic System Card Extensions

G.5.4 Usage and Maintenance Guidelines

G.6 Continuous Assurance Templates

G.6.1 Continuous Monitoring Checklist

G.6.2 AI System Audit Checklist

G.6.3 Smart-Contract Continuous Assurance Checklist

G.6.4 Digital Twin Assurance Checklist

Appendix H: RACI Matrices, Maturity Models and Decision Frameworks

H.1 RACI Matrices

H.1.1 AI Governance RACI

H.1.2 Agentic System Oversight RACI

H.1.3 Blockchain and Smart-Contract Security RACI

H.1.4 Digital Twin and Metaverse Security RACI

H.1.5 Post-Quantum Migration RACI

H.1.6 Incident Response (Hybrid Human + AI Agent) RACI

H.2 Maturity Models

H.2.1 Digital Trust Maturity Model

H.2.2 AI Governance Maturity Model

H.2.3 Agentic Systems Assurance Maturity Model

H.2.4 Post-Quantum Readiness Maturity Model

H.2.5 PETs Adoption Maturity Model

H.3 Decision Frameworks

H.3.1 AI System Risk Tiering Decision Framework

H.3.2 Autonomy Level Authorization Framework

H.3.3 Kill-Switch Activation Decision Framework

H.3.4 Smart-Contract Deployment Go / No-Go Framework

H.3.5 Quantum Migration Priority Decision Framework

Acronym	Full Form
AIMS	Artificial Intelligence Management System (ISO/IEC 42001)
AI RMF	Artificial Intelligence Risk Management Framework (NIST)
AgentOps	Agent Operations
AR	Augmented Reality
BCP	Business Continuity Plan
BIA	Business Impact Analysis
CBT	Computer-Based Testing
CISO	Chief Information Security Officer
CPE	Continuing Professional Education

DID	Decentralized Identifier
DRP	Disaster Recovery Plan
EDR	Endpoint Detection and Response
FHE	Fully Homomorphic Encryption
GRC	Governance, Risk and Compliance
HITL	Human-in-the-Loop
HOTL	Human-on-the-Loop
ICS	Industrial Control Systems
LLM	Large Language Model
LLMOps	Large Language Model Operations
MDR	Managed Detection and Response
MLOps	Machine Learning Operations
MPC	Multi-Party Computation (also SMPC)
MR	Mixed Reality
MTO	Maximum Tolerable Outage
NFT	Non-Fungible Token
OT	Operational Technology
PETs	Privacy-Enhancing Technologies
PQC	Post-Quantum Cryptography
RPO	Recovery Point Objective
RTO	Recovery Time Objective
SDO	Service Delivery Objective
SMPC	Secure Multi-Party Computation
TEE	Trusted Execution Environment
VR	Virtual Reality

XDR	Extended Detection and Response
XR	Extended Reality
ZKP	Zero-Knowledge Proof
zk-SNARK	Zero-Knowledge Succinct Non-Interactive Argument of Knowledge
zk-STARK	Zero-Knowledge Scalable Transparent Argument of Knowledge

Term	Definition
Agentic AI	AI systems capable of autonomous goal-directed behavior, planning, tool use, and multi-step decision-making with limited or no continuous human intervention.
Multi-Agent System	A system composed of multiple interacting intelligent agents that collaborate, compete, or coordinate to achieve individual or collective goals.
Goal Alignment	The process of ensuring that an AI agent's objectives remain consistent with human intentions and organizational values, even as the agent operates autonomously.
Goal Hijacking	A risk where an agentic system's objectives are manipulated or drift, causing it to pursue unintended or harmful goals.
Emergent Behavior	Unexpected collective behavior arising from interactions among multiple agents that was not explicitly programmed.
Kill-Switch / Circuit Breaker	A pre-defined technical and procedural mechanism that allows rapid suspension or termination of an autonomous AI agent's actions.
Human-in-the-Loop (HITL)	A control model where a human must approve or intervene in critical decisions made by an AI system.
Human-on-the-Loop (HOTL)	A control model where humans supervise AI systems and can intervene when necessary, but the system operates primarily autonomously.

Model Card	A standardized document that provides essential information about an AI model, including intended use, performance metrics, limitations, ethical considerations, and training data.
System Card	An extended documentation artifact that describes an entire AI system (including multiple models, agents, data pipelines, and human oversight mechanisms).
AI-as-a-CISO	An operating model in which AI systems significantly augment or partially automate traditional CISO functions such as continuous monitoring, prioritization, policy enforcement, and incident orchestration.
Digital Trust	The measurable confidence stakeholders have in the integrity, security, privacy, reliability, and ethical behavior of digital systems, data, and autonomous agents.
Privacy-Enhancing Technologies (PETs)	A family of technologies designed to protect data privacy while still enabling useful computation or analysis (includes homomorphic encryption, differential privacy, secure multi-party computation, zero-knowledge proofs, confidential computing, and federated learning).
Homomorphic Encryption	A form of encryption that allows computations to be performed directly on encrypted data without decrypting it.
Fully Homomorphic Encryption (FHE)	The strongest form of homomorphic encryption that supports arbitrary computations on ciphertext.
Differential Privacy	A mathematical framework that adds calibrated noise to data or query results to protect individual privacy while allowing aggregate analysis.
Zero-Knowledge Proof (ZKP)	A cryptographic method by which one party can prove to another that a statement is true without revealing any additional information.
Secure Multi-Party Computation (SMPC)	A cryptographic technique that enables multiple parties to jointly compute a function over their inputs while keeping those inputs private.
Confidential Computing	The protection of data in use by performing computation in a hardware-based Trusted Execution Environment (TEE).
Trusted Execution Environment (TEE)	A secure area of a processor that guarantees confidentiality and integrity of code and data loaded inside it.

Federated Learning	A machine learning approach where models are trained across decentralized devices or servers holding local data samples, without exchanging the raw data.
Post-Quantum Cryptography (PQC)	Cryptographic algorithms designed to be secure against attacks by both classical and quantum computers.
Crypto-Agility	The ability of a system to rapidly switch between cryptographic algorithms or parameters without significant redesign.
Harvest-Now-Decrypt-Later	An attack strategy in which encrypted data is collected today with the intention of decrypting it in the future when quantum computers become capable.
Digital Twin	A dynamic virtual representation of a physical object, process, or system that is continuously updated with real-world data.
Industrial Metaverse	The application of metaverse and digital twin technologies to industrial environments for simulation, optimization, collaboration, and control.
Spatial Computing	Computing paradigms that understand and interact with the physical space around the user (includes XR, digital twins, and spatial mapping).
Extended Reality (XR)	An umbrella term covering Virtual Reality (VR), Augmented Reality (AR), and Mixed Reality (MR).
Neuromorphic Computing	Computing architectures inspired by the structure and function of biological neural systems, often using spiking neural networks.
TinyML	Machine learning models and techniques optimized to run on extremely resource-constrained edge devices.
Decentralized Identifier (DID)	A globally unique identifier that is created, owned, and controlled by the entity it identifies, independent of any centralized registry.
Verifiable Credential	A tamper-evident credential that can be cryptographically verified and is typically issued, held, and presented in a decentralized identity ecosystem.
Smart Contract	A self-executing program stored on a blockchain that automatically enforces the terms of an agreement when predefined conditions are met.

Formal Verification	The use of mathematical methods to prove that a system (especially a smart contract) satisfies its formal specification.
Oracle (Blockchain)	A service that provides external real-world data to smart contracts.
Model Poisoning	An attack in which an adversary manipulates training data or the training process to cause a machine learning model to behave incorrectly.
Prompt Injection	An attack technique against large language models where malicious instructions are embedded in user input to override the system's intended behavior.
Deepfake	Synthetic media (image, audio, or video) generated by AI that convincingly depicts people saying or doing things they never did.
Synthetic Data	Artificially generated data that mimics the statistical properties of real data while protecting privacy or enabling testing.
Cascading Risk	Risk that propagates across interconnected systems, agents, or domains, often amplifying impact.
Cyber-Physical System	An engineered system that tightly integrates computational and physical components.
Space Systems Security	Security of ground segments, space segments, and communication links of satellites and space-based assets.

CISM® Review Manual

Advanced Future-Proof Edition — July 2026

Table of Contents

(Original 16th Edition structure fully preserved — only internal expansions for 2026 technologies)

About This Manual

- Overview
- Organization of This Manual
- Format of This Manual
- Preparing for the CISM Exam
- Getting Started
- Using the CISM Review Manual
- Features in the Review Manual
- Types of Questions on the CISM Exam

- Preparing for the Exam
 - Using ISACA Exam Preparation Resources
 - About the CISM Review Questions, Answers & Explanations Manual
 - About the CISM Review Questions, Answers & Explanations Database
-

Chapter 1: Information Security Governance

Overview

- Domain 1 Exam Content Outline
- Learning Objectives/Task Statements
- Suggested Resources for Further Reading

Part A: Enterprise Governance

1.1 Importance of Information Security Governance

1.1.1 Outcomes of Information Security Governance

(including digital trust, AI trustworthiness, quantum readiness and cyber-physical resilience)

1.1.2 Scope and Charter of Information Security Governance

(covering AI systems, multi-agent ecosystems, blockchain networks, digital twins, XR environments and edge AI)

1.2 Organizational Culture

1.2.1 General Rules of Use / Acceptable Use Policy

(traditional + AI Acceptable Use + Agentic AI Autonomy + Synthetic Media policies)

1.2.2 Ethics

(human-AI collaboration ethics, algorithmic fairness, metaverse identity ethics)

1.3 Legal, Regulatory and Contractual Requirements

1.3.1 Requirements for Content and Retention of Business Records

(AI training data provenance, model cards, blockchain immutable logs, synthetic data lineage)

1.4 Organizational Structures, Roles and Responsibilities

1.4.1 Roles and Responsibilities

- Skills
- Board of Directors
- Senior Management
- Business Process Owners
- Steering Committee

- Chief Information Security Officer (including AI-as-a-CISO operating model)
- Risk Management Roles and Responsibilities

Part B: Information Security Strategy

1.5 Information Security Strategy Development

1.5.1 Business Goals and Objectives

1.5.2 Information Security Strategy Objectives

1.5.3 Ensuring Objective and Business Integration

- Business Linkages 1.5.4 Avoiding Common Pitfalls and Bias 1.5.5 The Desired State
- COBIT
- Business Model for Information Security
- Governance, Risk Management and Compliance 1.5.6 Information Security Strategy Development 1.5.7 Elements of a Strategy
- Road Map
- Resources and Constraints—Overview

1.6 Information Governance Frameworks and Standards

1.6.1 Balanced Scorecard

1.6.2 Architectural Approaches

1.6.3 Enterprise Risk Management Frameworks

1.6.4 Information Security/Cybersecurity Management Frameworks and Models

- ISO/IEC 27000 Series + ISO/IEC 42001
- NIST Cybersecurity Framework
- NIST Risk Management Framework
- NIST AI Risk Management Framework
- Other Approaches

1.7 Strategic Planning

1.7.1 Workforce Composition and Skills

- Organizational Structure
- Centralized and Decentralized Approaches to Coordinating Information Security
- Employee Roles and Responsibilities
- Skills
- Awareness and Education 1.7.2 Assurance Provisions
- Audits
- Compliance Enforcement 1.7.3 Risk Assessment and Management
- Business Impact Analysis
- Resource Dependency Analysis
- Outsourced Services
- Threat Assessment

- Vulnerability Assessment
 - Insurance
 - Other Organizational Support and Assurance Providers 1.7.4 Action Plan to Implement Strategy
 - Gap Analysis—Basis for an Action Plan
 - Action Plan Metrics
 - Action Plan Intermediate Goals 1.7.5 Information Security Program Objectives
-

Chapter 2: Information Security Risk Management

Overview

- Domain 2 Exam Content Outline
- Learning Objectives/Task Statements
- Suggested Resources for Further Reading

Part A: Information Risk Assessment

2.1 Emerging Risk and Threat Landscape

2.1.1 Risk Identification

2.1.2 Threats

- Internal Threats
- External Threats
- Advanced Persistent Threats 2.1.3 Defining a Risk Management Framework
- Defining the External Environment
- Defining the Internal Environment 2.1.4 Emerging Threats (Agentic AI, generative AI, blockchain/smart-contract, metaverse/digital twin, quantum, edge AI, synthetic data and cyber-physical risks) 2.1.5 Risk, Likelihood and Impact 2.1.6 Risk Register

2.2 Vulnerability and Control Deficiency Analysis

2.2.1 Security Control Baselines

2.2.2 Events Affecting Security Baselines

2.3 Risk Analysis, Evaluation and Assessment

2.3.1 Determining the Risk Management Context

2.3.2 Operational Risk Management

2.3.3 Risk Management Integration with IT Life Cycle Management Processes

2.3.4 Risk Scenarios

2.3.5 Risk Assessment Process

2.3.6 Risk Assessment and Analysis Methodologies

- NIST Risk Assessment Methodology
- ISO/IEC Process Steps
- Cascading Risk 2.3.7 Other Risk Assessment Approaches
- Factor Analysis of Information Risk (FAIR)
- Holistic Approach to Risk Management (HARM)
- Probabilistic Risk Assessment 2.3.8 Risk Analysis
- Gap Analysis
- Qualitative Analysis
- Semi-quantitative (Hybrid) Analysis
- Quantitative Analysis
- Other Risk Analysis Methods 2.3.9 Risk Evaluation 2.3.10 Risk Ranking

Part B: Information Risk Response

2.4 Risk Treatment / Risk Response Options

2.4.1 Determining Risk Capacity and Acceptable Risk (Risk Appetite)

2.4.2 Risk Response Options

- Terminate the Activity
- Transfer the Risk
- Mitigate the Risk
- Accept the Risk 2.4.3 Risk Acceptance Framework 2.4.4 Inherent and Residual Risk
2.4.5 Impact 2.4.6 Controls 2.4.7 Legal and Regulatory Requirements 2.4.8 Costs and Benefits

2.5 Risk and Control Ownership

2.5.1 Risk Ownership and Accountability

2.5.2 Risk Owner

2.5.3 Control Owner

2.6 Risk Monitoring and Reporting

2.6.1 Risk Monitoring

2.6.2 Key Risk Indicators

2.6.3 Reporting Changes in Risk

2.6.4 Risk Communication, Awareness and Consulting

- Risk Awareness 2.6.5 Documentation

Chapter 3: Information Security Program Development and Management

Overview

- Domain 3 Exam Content Outline
- Learning Objectives/Task Statements
- Suggested Resources for Further Reading

Part A: Information Security Program Development

3.1 Information Security Program Overview

- 3.1.1 Information Security Management Trends
- 3.1.2 Essential Elements of an Information Security Program
- 3.1.3 Importance of the Information Security Program
- 3.1.4 Applying the Security Program Business Case
- 3.1.5 Outcomes of Information Security Program Management
 - Strategic Alignment
 - Risk Management
 - Value Delivery
 - Resource Management
 - Performance Measurement
 - Assurance Process Integration

3.2 Information Security Program Resources

- 3.2.1 Information Security Program Objectives
 - Defining Objectives
- 3.2.2 Information Security Program Concepts
 - Management and Process Concepts
 - Technology Resources
- 3.2.3 Scope and Charter of an Information Security Program
- 3.2.4 Common Information Security Program Challenges
 - Management Support
 - Funding
 - Staffing
- 3.2.5 Common Information Security Program Constraints
 - Physical
 - Ethics
 - Culture
 - Organizational Structure
 - Costs
 - Personnel
 - Resources
 - Capabilities
 - Time
 - Technology

3.3 Information Asset Identification and Classification

- 3.3.1 Information Asset Identification and Valuation
- 3.3.2 Information Asset Valuation Strategies

3.3.3 Information Asset Classification

3.3.4 Methods to Determine Criticality of Assets and Impact of Adverse Events

3.4 Industry Standards and Frameworks for Information Security

3.4.1 Enterprise Information Security Architectures

- Alternative Enterprise Architecture Frameworks
- Enterprise Architecture Domains
- Objectives of Information Security Architectures
- COBIT
- ISO/IEC 27001
- NIST Cybersecurity Framework
- NIST Risk Management Framework
- Technical Components
- Operational Components
- Management Components
- Administrative Components
- Educational and Informational Components

3.5 Information Security Policies, Procedures and Guidelines

3.5.1 Policies

- Policy Development
- Standards Development
- Procedures
- Guidelines

3.6 Defining an Information Security Program Road Map

3.6.1 Applying Frameworks and Architectures to Create a Program Road Map

- Simplicity and Clarity Through Layering and Modularization
- Business Focus Beyond the Technical Domain
- Architecture and Control Objectives
- Architecture Implementation
- Security Program Management and Administrative Activities
- Program Administration
- Gap Analysis as the Basis for an Action Plan
- Life Cycle Principles Supporting the Road Map

3.7 Information Security Program Metrics

3.7.1 Effective Security Metrics

- Governance Implementation Metrics
- Strategic Alignment Metrics
- Risk Management Metrics
- Value Delivery Metrics
- Resource Management Metrics
- Performance Measurement 3.7.2 Security Program Metrics and Monitoring 3.7.3 Metrics Tailored to Enterprise Needs
- Strategic
- Management
- Operational

Part B: Information Security Program Management

3.8 Information Security Control Design and Selection

3.8.1 Managing Risk Through Controls

- IT Controls
- Non-IT Controls
- Layered Defenses
- Technologies 3.8.2 Controls and Countermeasures 3.8.3 Control Categories 3.8.4 Control Design Considerations 3.8.5 Control Methods
- Countermeasures
- Physical and Environmental Controls
- Control Technology Categories
- Technical Control Components and Architecture

3.9 Information Security Control Implementation and Integration

3.9.1 Baseline Controls

3.10 Information Security Control Testing and Evaluation

3.10.1 Control Strength

3.10.2 Control Recommendations

3.10.3 Control Testing and Modification

3.11 Information Security Awareness and Training

3.11.1 Security Awareness Training and Education

3.11.2 Developing an Information Security Awareness Program

3.11.3 Role-Based Training

3.11.4 Training and Education Metrics

3.12 Integration of the Security Program With IT Operations

3.12.1 Personnel, Roles, Skills and Culture

- Roles
- Skills
- Documentation
- Document Maintenance 3.12.2 Information Security Liaison Responsibilities
- Physical/Corporate Security
- IT Audit
- Information Technology
- Business Unit Managers
- Human Resources
- Legal Department
- Employees
- Procurement
- Compliance
- Privacy
- Training
- Quality Assurance
- Insurance
- Third-party Management
- Project Management Office 3.12.3 Cross-Organizational Responsibilities 3.12.4 Issue Resolution through the Information Security Program
- Vendor Management
- Physical and Environmental Factors
- Cultural and Regional Variances
- Logistics 3.12.5 Integration With IT Processes
- Integration
- System Development Life Cycle Processes
- DevOps and DevSecOps
- Change Management
- Configuration Management
- Release Management 3.12.6 Cloud Computing
- Cloud Service Models
- Advantages
- Evaluation of Cloud Service Providers

3.13 Management of External Services and Relationships

3.13.1 Governance of Third-Party Relationships

3.13.2 Third-Party Service Providers

- Outsourcing and Service Providers 3.13.3 Outsourcing Challenges 3.13.4 Outsourcing Contracts 3.13.5 Third-Party Access

3.14 Information Security Program Communications and Reporting

3.14.1 Program Management Evaluation

- Program Objectives
- Compliance Requirements
- Program Management
- Security Operations Management
- Technical Security Management
- Resource Levels 3.14.2 The Plan-Do-Check-Act Cycle 3.14.3 Security Reviews and Audits
- Audits
- Auditors 3.14.4 Compliance Monitoring and Enforcement
- Policy Compliance
- Standards Compliance
- Resolution of Noncompliance Issues
- Compliance Enforcement 3.14.5 Monitoring Approaches
- Monitoring Security Activities in Infrastructure and Business Applications
- Determining Success of Information Security Investments 3.14.6 Measuring Information Security Management Performance
- Measuring Information Security Risk and Loss
- Measuring Support of Organizational Objectives
- Measuring Compliance
- Measuring Operational Productivity
- Measuring Security Cost-Effectiveness
- Measuring Organizational Awareness
- Measuring Effectiveness of Technical Security Architecture
- Measuring Effectiveness of Management Framework and Resources
- Measuring Operational Performance 3.14.7 Ongoing Monitoring and Communication

Chapter 4: Incident Management

Overview

- Domain 4 Exam Content Outline
- Learning Objectives/Task Statements
- Suggested Resources for Further Reading

Part A: Incident Management Readiness

4.1 Incident Management and Incident Response Overview

4.1.1 The Relationship Between Incident Management and Incident Response

4.1.2 Goals of Incident Management and Incident Response

4.1.3 Incident Handling and Incident Management Life Cycle

4.2 Incident Management and Incident Response Plans

4.2.1 Importance of Incident Management

4.2.2 Outcomes of Incident Management
4.2.3 Incident Management Resources
4.2.4 Policies and Standards
4.2.5 Incident Management Objectives
4.2.6 Strategic Alignment
4.2.7 Response and Recovery Plan
4.2.8 The Role of the Information Security Manager in Incident Management
4.2.9 Risk Management
4.2.10 Assurance Process Integration
4.2.11 Value Delivery
4.2.12 Resource Management
4.2.13 Defining Incident Management Procedures
4.2.14 Detailed Plan of Action for Incident Management

4.2.15 Current State of Incident Response Capability

- History of Incidents
 - Threats
 - Vulnerabilities
- 4.2.16 Developing an Incident Response Plan
- Elements of an Incident Response Plan
 - Gap Analysis—Basis for an Incident Response Plan
 - Logistics
- 4.2.17 Incident Management and Response Teams 4.2.18 Organizing, Training and Equipping the Response Staff 4.2.19 Incident Notification Process 4.2.20 Challenges in Developing an Incident Management Plan

4.3 Business Impact Analysis

4.3.1 Elements of a Business Impact Analysis

4.3.2 Benefits of Conducting a Business Impact Analysis

4.4 Business Continuity Plan

4.4.1 Integrating Incident Response With Business Continuity

4.4.2 Methods for Providing Continuity of Network Services

4.4.3 High-Availability Considerations

4.4.4 Insurance

4.5 Disaster Recovery Plan

4.5.1 Business Continuity and Disaster Recovery Procedures

4.5.2 Recovery Operations

4.5.3 Evaluating Recovery Strategies

4.5.4 Addressing Threats

4.5.5 Recovery Sites

4.5.6 Basis for Recovery Site Selections

4.5.7 Response and Recovery Strategy Implementation

4.6 Incident Classification / Categorization

4.6.1 Escalation Process for Effective Incident Management

4.6.2 Help/Service Desk Processes for Identifying Security Incidents

4.7 Incident Management Training, Testing and Evaluation

4.7.1 Incident Management Roles and Responsibilities

- Senior Management Commitment
- Responsibilities 4.7.2 Incident Management Metrics and Indicators
- Recovery Time Objectives
- Recovery Point Objectives
- Service Delivery Objectives
- Maximum Tolerable Outage
- Allowable Interruption Window 4.7.3 Performance Measurement 4.7.4 Updating Recovery Plans 4.7.5 Testing Incident Response and Business Continuity/Disaster Recovery Plans 4.7.6 Periodic Testing of the Response and Recovery Plans 4.7.7 Testing for Infrastructure and Critical Business Applications 4.7.8 Types of Tests 4.7.9 Test Results 4.7.10 Recovery Test Metrics

Part B: Incident Management Operations

4.8 Incident Management Tools and Technologies

4.8.1 Incident Management Systems

- Endpoint Detection and Response
- Extended Detection and Response
- Managed Detection and Response 4.8.2 Incident Response Technology Foundations
- 4.8.3 Personnel
- Incident Response Team Organization
- Roles and Responsibilities 4.8.4 Skills 4.8.5 Awareness and Education 4.8.6 Audits 4.8.7 Outsourced Security Providers

4.9 Incident Investigation and Evaluation

4.9.1 Executing Response and Recovery Plans

- Ensuring Execution as Required

4.10 Incident Containment Methods

4.11 Incident Response Communications

4.11.1 Notification Requirements

4.11.2 Communication Networks

4.12 Incident Eradication and Recovery

4.12.1 Eradication Activities

4.12.2 Recovery

4.13 Post-Incident Review Practices

4.13.1 Identifying Causes and Corrective Actions

4.13.2 Documenting Events

4.13.3 Establishing Legal Procedures to Assist in Post-incident Activities

4.13.4 Requirements for Evidence

4.13.5 Legal Aspects of Forensic Evidence